

UNCLASSIFIED



National Geospatial-Intelligence Agency

DIRECTIVE

NUMBER 8010

27 August 2015

Administrative Update 16 November 2015

CIO-T

SUBJECT: Information Systems Risk Management Framework (RMF)

References: See Enclosure 1.

1. PURPOSE. This NGA Directive (NGAD):

a. Establishes policy and assigns responsibilities for the Information Systems RMF and for the assessment and authorization (A&A) of NGA Information Technology (IT) systems in accordance with (IAW) References (a) through (g).

b. Rescinds NGA Instruction 8010.3, "Certification and Accreditation of Information Systems," 22 August 2007 (Reference (o)).

2. APPLICABILITY. This NGAD applies to all civilian employees, military service members assigned to NGA, other Government agency personnel permanently assigned to NGA, and NGA contract support personnel who design, build, procure, test, operate, maintain, and dispose of NGA information systems.

3. DEFINITIONS. See Glossary.

4. POLICY. It is NGA policy to:

a. Determine levels of confidentiality, integrity, and availability in information systems that balance the values of mission needs, related information, schedule, and security.

b. Enable discoverability of data between and across information systems.

c. Integrate information system security control requirements into the System Development Lifecycle (SDLC) IAW References (f) and (g) and the Acquisition Lifecycle.

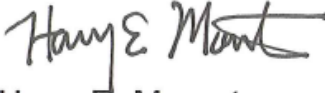
d. Ensure IT systems undergo A&A using the information systems security RMF process IAW Reference (d).

UNCLASSIFIED

- e. Continuously monitor information systems throughout the SDLC including all changes.
- f. Apply information types during the categorization of systems IAW References (b) and (d).
- g. Provide enterprise security services through the Common Control Provider (CCP) IAW References (b) and (c).

5. RESPONSIBILITIES. See Enclosure 2.

6. EFFECTIVE DATE. This NGAD is effective on the date of signature (Reference (q)).


Harry E. Mornston
Chief of Staff

Enclosures

- 1. References
 - 2. Responsibilities
- Glossary

ENCLOSURE 1

REFERENCES

- (a) Committee on National Security Systems Instruction (CNSSI) 4009, "National Information Assurance Glossary," 26 April 2010
- (b) CNSSI 1253, "Security Categorization and Control Selection for National Security Systems," 15 March 2012
- (c) National Institute of Standards and Technology (NIST) Special Publication (SP) 800-53, Revision 4, "Recommended Security Controls for Federal Information Systems and Organizations," August 2009, as amended
- (d) NIST SP 800-37, Revision 1, "Guide for Applying the Risk Management Framework to Federal Information Systems," February 2010
- (e) NIST SP 800-64, Revision 2, "Security Considerations in the System Development Life Cycle," October 2008
- (f) Intelligence Community Directive 503, "Information Technology Systems Security Risk Management, Certification and Accreditation," 21 July 2015
- (g) DoD Directive 8000.01, "Management of the Department of Defense Information Enterprise," 10 February 2009
- (h) DoD Instruction 8570.01-M, "Information Assurance Workforce Improvement Program," 02 February 2010
- (i) NGA Directive (NGAD) 5425.3, "National Geospatial-Intelligence Agency (NGA) Policy Program," 02 November 2012
- (j) NGAD 8000, "Information Management and the Chief Information Officer," 12 June 2013
- (k) NGAD 5200.2, "Personnel Security," 18 May 2014
- (l) NGAD 3020, "Business Continuity/Disaster Recovery (BC/DR) Program," 06 June 2014
- (m) NGA Instruction (NGAI) 5210.8, "Physical Security," 08 November 2010
- (n) NGA Instruction (NI) 5425.1, "Policy Program," 02 November 2012
- (o) NI 8010.3, "Certification and Accreditation of Information Systems," 22 August 2007 (hereby rescinded)
- (p) NGA Manual 8010.1, "Information Systems (IS) Risk Management Framework (RMF) Guide," 24 July 2015
- (q) Email from Director, NGA, to Chief of Staff, NGA, "Policy Signature Designation Note," 05 June 2015

ENCLOSURE 2RESPONSIBILITIES

1. Director, NGA (D/NGA).

a. Designates, in writing, an Authorizing Official (AO) to make A&A decisions IAW References (f) and (g). Authorizes further delegation.

b. Retains responsibility for all A&A and associated risk management decisions made on his/her behalf (References (f) and (g)).

2. ~~Open IT Portfolio Manager~~ *Chief Information Officer* approves or disapproves major information system investment and divestment decisions.

3. AO, also known as the Chief Information Security Officer.

a. Approves all A&A for IT systems to include those systems for which NGA has been designated as Executive Agent on behalf of the Intelligence Community enterprise (References (f) and (g)).

b. Ensures information systems operate at an acceptable level of risk IAW References (f) and (g) and are disposed of appropriately.

c. Assigns risk weighting to competing equities of mission and security requirements, reviews budget consequences, operational performance efficiencies, schedule requirements, counterintelligence concerns, information sharing, civil liberties and privacy protection, and other relevant policy requirements.

d. Designates, in writing, Delegated Authorizing Official(s) (DAO) to authorize operations for moderate or low impact systems on his/her behalf.

e. Appoints one or more Executive Agent(s) to deliver enterprise security services/CCPs and to provide, when possible, a set of security controls IAW References (a) through (g) and (i).

f. Forms a panel to review all high impact systems to recommend authorizations.

g. Ensures personnel responsible for IT security are adequately trained IAW Reference (h).

h. Reports annually to D/NGA on the effectiveness of IT security programs, including the progress of remedial actions.

4. DAO.

- a. Acts on behalf of the AO for information systems when designated.
- b. Documents and tracks A&A actions.

5. Director, Information Technology Services and Chief Information Officer (D/T-CIO).

- a. Acquires, operates, and maintains IT and assigned enterprise security services infrastructure IAW References (b) through (d).
- b. Maintains authorized security levels for all information systems throughout their operational life cycle.
- c. Ensures all information systems' security changes and redesigns are coordinated with the applicable AO or DAO (depending on the approval level).
- d. Serves as the Information System Security Manager who maintains awareness of new acquisitions, recapitalization, redesign, and security-relevant changes.
- e. Assigns information system security engineering requirements and information system plan of action and milestones.
- f. Designates, in writing, and oversees the Program Managers/Project Managers (PM) for all NGA information systems.
- g. Issues and approves NGA Manual (NGAM) 8010.1 (Reference (p)), which implements policy, assigns responsibilities, and provides guidance and procedures IAW NGA Corporate Policy (References (i) and (n)).

~~6. Director, Human Development.~~

- ~~a. Ensures testing of IT functionality in support of Human Resources Information Systems (HRIS) IAW Reference (b) and (c).~~
- ~~b. Maintains access to the HRIS according to mission requirements/role security.~~

67. Chief, NGA Operations Center–Mission Assurance.

- a. In collaboration with the AO and D/T, designs, acquires, operates, and maintains security controls specified for each information system for business continuity and disaster recovery purposes IAW References (b) and (l).
- b. Provides enabling technology (via the continuity planning tool) to capture and associate information systems, essential functions, and return to operations to assess/mitigate risk.

c. Assists Components in determining system availability levels through association with the mission/business functions IAW Reference (l).

d. Supports PMs in determining systems recovery priorities according to mission needs during a contingency.

78. Director, Security and Installations.

a. In collaboration with the AO and D/T-CIO, designs, acquires, operates, and maintains physical security, personnel security, and environmental services infrastructure in support of information systems IAW References (d) and (k).

b. Maintains authorized security levels for all facility services in support of information systems throughout their operational lifecycle IAW References (d) and (k).

89. PMs, also known as Information System Owners (ISO).

a. Procure, develop, integrate, modify, or operate and maintain information systems IAW Reference (c) and this Directive.

b. Appoint a program Information Systems Security Engineer to perform cybersecurity functions within the scope of the program.

c. Develop, submit, publish, and maintain the Body of Evidence (BOE) for IT systems throughout their operational life cycle.

d. Develop information systems Security Test Plans IAW Reference (d).

e. Appoint an Information Systems Security Officer for each authorized information system.

910. Chair, Information Technology Executive Council, as the Risk Executive Function.

a. Advises AO and DAO by reviewing individual information systems risks to include A&A decisions. Ensures individual information systems are considered in an integrated fashion as a system of systems IAW References (d), (f), and (g).

b. Ensures information systems security risks are minimized and mitigated.

c. Balances information systems risk tolerance with other Agency risks such as mission, schedule, and financial in order to ensure mission/business success.

GLOSSARYPART I. ACRONYMS

A&A	Assessment and Authorization
AO	Authorizing Official
BOE	Body of Evidence
CCP	Common Control Provider
DAO	Delegated Authorizing Official
D/NGA	Director, NGA
D/T-CIO	Director, IT Services and Chief Information Officer
HRIS	Human Resources Information System
ISO	Information System Owners
IT	Information Technology
NGAM	NGA Manual
PM	Program Manager
RMF	Risk Management Framework
SDLC	System Development Lifecycle

PART II. DEFINITIONS

Assessment	The testing and/or evaluation of the management, operational, and technical security controls in an information system to determine the extent to which the controls are implemented correctly, operating as intended, and producing the desired outcome with respect to meeting the security requirements for the system (References (d) and (e)).
Authorization	The official management decision given by a senior organizational official to authorize operation of an information system and to explicitly accept the risk incurred to organizational operations (including mission, functions, image, or reputation), organizational assets, individuals, other organizations, and the nation based on the implementation of an agreed-upon set of security controls (References (a), (c), and (d)).
Authorizing Official (AO)	Senior Executive Services-level officer with the authority to formally assume responsibility for operating an information system at an acceptable level of risk to organizational operations (including mission, functions, image, or reputation),

	organizational assets, individuals, other organizations, and the nation. Appointed by D/NGA to make authorization decisions on behalf of D/NGA (Reference (c)).
Body of Evidence (BOE)	The set of data that documents the information system's adherence to the security controls applied. The BOE will include a requirements verification traceability matrix delineating where the selected security controls are met and evidence to that fact can be found. The BOE content required by an AO will be adjusted according to the impact levels selected (Reference (c)).
Common Control Provider (CCP)	An individual, group, or Component responsible for the planning, development, implementation, assessment, authorization, and monitoring of common security controls (i.e., security controls with which multiple Components must comply). NGA has multiple CCPs (Reference (d)).
Delegated Authorizing Official (DAO)	Appointed by the AO to expedite authorization approval of designated systems and provide mission support for moderate to low impact systems (Reference (f) and (g)).
Information System	A discrete set of information resources organized for the collection, processing, maintenance, use, sharing, dissemination, or disposition of information (Note: information systems also include specialized systems such as industrial/process controls systems, telephone switching and private exchange systems, and environmental control systems) (References (c) and (e)).
Information System Owner (ISO)	An ISO is responsible for the overall design, build, procurement, development, test, integration, modification, operation, maintenance, and disposal of an information system (as well as the system components) to include development and provision of the security plan.
Information System Security Officer	Individual with assigned responsibility for maintaining the appropriate operational security posture for an information system or program (References (c) and (d)).
Information Type	A specific category of information (e.g., private, medical, proprietary, financial, investigative, contractor sensitive, security management) defined by an organization, or in some instances, by a specific law, Executive Order, directive, policy, or regulation (References (a), (e), (b), and (d)).
Program/Project Managers (PM)	A system's government ISO. PM, as designated by the Component, is the government official responsible for the

procurement, development, integration modification, operation, maintenance, and disposal of an information system.

Risk Management

The process of managing risks to Agency operations (including mission, functions, image, or reputation), Agency assets, or individuals, resulting from the operation of an information system. It includes risk assessment; cost-benefit analysis; selection, implementation, and assessment of security controls; and formal authorization to operate the system. The process considers effectiveness, efficiency, and constraints due to laws, directives, policies, or regulations (Reference (a)).

Risk Management Framework (RMF)

Guidelines for conducting the activities of security categorization, security control selection and implementation, security control assessment, information system authorization, and security control monitoring. These guidelines ensure managing information system-related security risks are consistent with the organization's mission/business objectives and overall risk strategy established by the senior leadership; ensure information security requirements are integrated into the organization's enterprise architecture and SDLC processes; support consistent, well-informed, and ongoing security authorization decisions, transparency of security and risk management-related information, and reciprocity; and achieve secure information and information systems within the Federal government through the implementation of appropriate risk mitigation strategies.